ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Siemens SIMATIC S7-1500 / S7-1200 PLC · Component type: **Embedded Device (EDR) - PLC/PAC** · Target SL = SL 3

Where to work	**TIA Portal** (Device configuration › **Protection & Security**): access-protection levels, password-protected/**know-how protection** blocks, copy protection, PROFINET/OPC UA security, certificates; CPU **display** (local PIN); Web server config; SINEC / Security Event log.
Interfaces / ports	S7-Comm/S7CommPlus (TCP 102), PROFINET, OPC UA (4840), Web server (80/443), SNMP, time sync. Engineer via TIA Portal; HMI via SIMATIC HMI.
Notes	EDR (embedded PLC). Applies to S7-1500 / S7-1200 (V2.x+); confirm CPU firmware and whether F-CPU (fail-safe). Higher security features (Secure Comm/OPC UA/Security events) need current firmware.
How to read	Read-only: review the TIA Portal project + CPU online settings. Native how-to + external-tool validation + pass. Scans authorized; fuzz/exploit only in an isolated/lab environment with written authorization.

Project / config capture & evidence handling - capture the device backup + config export

Do this BEFORE working the checklist - screenshots and walking the config screens are not enough on their own. Capture the device's own backup / project export so nothing is missed:
1. Pull the native backup / project + full config export first (read-only, before anything): the TIA Portal project (.ap<ver>) + an **online 'Upload from device'** backup, the Protection & Security access level + know-how/copy protection, the PROFINET/OPC UA + certificate config, firmware rev, and the CPU **diagnostic buffer** export.
2. Export the security-relevant settings: user accounts / roles / password policy, comms / port / protocol enable-disable, and any certificate / key / CIP-Security settings - as files and screenshots.
3. Collect firmware & logs: firmware / boot revision, and the event / audit / diagnostic logs and fault / alarm buffers (exports) where the device provides them.
4. Capture the device identity: nameplate (catalog + serial), firmware / hardware rev, installed modules / option cards, and slot / network address - **photograph** the device, faceplate / HIM and panel labels.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<vendor>_<model>_<fwRev>_<YYYYMMDD-HHMM>_<initials>` with the native project / backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup may hold credentials / keys - **never** email it in cleartext and follow the project retention / classification policy. Do not save device passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user identification & auth	TIA Portal › CPU properties › **Protection & Security › Access level**: set the highest appropriate tier — **No access (complete protection)** or **HMI access** — each higher tier gated by a password (levels: Full access / Read access / HMI access / No access). Enable **UMAC** (User Management & Access Control, TIA V19+) for per-user roles; define named users for OPC UA/Web. **Ext. tools:** TIA Portal (Access level / UMAC review); attempt anonymous connect (isolated).	Access requires authentication; access level set to HMI/No-access with passwords.	
SR/CR 1.2	Software process / device identification	Confirm the CPU and each comm partner (HMI, SCADA, engineering) are uniquely identified (device name/IP, PROFINET name) and mutually configured; OPC UA / Secure Comm bind partners by certificate. **Ext. tools:** TIA Portal (device/partner config); Wireshark (partner identity).	Unique device identity; comm partners identified/bound.	
SR/CR 1.3	Account management	Manage the protection-level passwords and OPC UA/Web user accounts (create/change/remove); no shared/default passwords; least-privilege roles (e.g. HMI vs engineering). **Ext. tools:** TIA Portal (users/roles review).	Accounts managed, least-privilege; defaults changed.	
SR/CR 1.4	Identifier management	Confirm unique user identifiers (OPC UA/Web users) and a unique CPU identity (PROFINET device name, IP, serial); no reuse across devices. **Ext. tools:** TIA Portal; network inventory.	Unique user and device identifiers; no reuse.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.5	Authenticator management	Enforce strong protection-level and OPC UA/Web passwords; change from defaults; where the CPU display is used, set a **display PIN**; manage password lifecycle in the project. **Ext. tools:** TIA Portal (password policy); display-PIN check.	Strong, managed authenticators; display PIN set; no defaults.	
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	PKI certificates	For **Secure Communication** / OPC UA / HTTPS, use TIA Portal certificate management: device certificates issued by the project/enterprise CA, valid, not default self-signed; manage trust list. **Ext. tools:** TIA Portal (certificate manager); openssl (OPC UA/HTTPS cert).	CA-issued, valid certificates for secure channels; defaults replaced.	
SR/CR 1.9	Strength of public key auth	Confirm OPC UA / Secure Comm / HTTPS use strong certificates and TLS (current cipher suites); no weak/expired certs; OPC UA security policy Basic256Sha256 or better. **Ext. tools:** testssl.sh (443/4840); OPC UA client (security policy check).	Strong certificate/TLS crypto on secure channels.	
SR/CR 1.10	Authenticator feedback	Confirm TIA Portal, HMI, Web server, and CPU display mask password entry (no cleartext echo). **Ext. tools:** Visual verification at each interface.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Confirm brute-force resistance: repeated wrong passwords are rejected/delayed on the protection level, OPC UA/Web logins, and the display PIN; monitor failed attempts via the security event log. **Ext. tools:** TIA Portal / display (lockout test, isolated); SIEM (failed-auth events).	Repeated failed logins throttled/locked; attempts logged.	
SR/CR 1.12	System use notification	No native PLC banner; enforce the approved use-notification on the engineering workstation and HMI (compensating). Where the Web server allows a message, set it. **Ext. tools:** EWS/HMI banner review; Web server config.	Approved use notice at EWS/HMI (compensating at PLC level).	Compensating.
SR 1.13	Access via untrusted networks	Confirm remote/engineering access is only from trusted zones: TCP 102/OPC UA/Web reachable only via the cell firewall / SCALANCE, VPN for remote; deny from untrusted networks. **Ext. tools:** Nmap (from untrusted side); firewall/SCALANCE rule review.	Access from untrusted networks denied/brokered; remote via VPN only.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	Confirm the access-protection level enforces what each partner may do (HMI read vs engineering write); **know-how protection** restricts block access; program change requires the engineering password. **Ext. tools:** TIA Portal (protection + know-how review); attempt unauthorized write (isolated).	Least-privilege enforced; program change requires authorization.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable/mobile devices	Control the **SIMATIC Memory Card** and engineering laptop: card handling policy, project files controlled, removable-media policy on the EWS; only authorized project loaded. **Ext. tools:** Physical inspection; EWS removable-media policy.	Memory card / engineering media controlled.	
SR/EDR 2.4	Mobile code	No general-purpose mobile code on the CPU; confirm only the compiled STEP 7 program runs, Web server active content is restricted, and no untrusted code loads. **Ext. tools:** TIA Portal (program/Web review).	Only the trusted compiled program runs; no untrusted mobile code.	EDR-specific.
SR/CR 2.5	Session lock	Confirm inactivity handling: HMI/engineering sessions lock/timeout, OPC UA/Web sessions expire on inactivity, and re-authentication is required. **Ext. tools:** TIA Portal/HMI timeout config; OPC UA session review.	Sessions lock/expire on inactivity; re-auth required.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.6	Remote session termination	Confirm engineering/OPC UA/Web sessions can be terminated and idle sessions close; the access-protection list limits who can reconnect. **Ext. tools:** TIA Portal (online connection status); Wireshark.	Remote sessions terminable on demand and on inactivity.	
SR/CR 2.7	Concurrent session control	Confirm concurrent programming/HMI access is bounded: reservation prevents conflicting simultaneous programming; OPC UA/Web max sessions limited. **Ext. tools:** TIA Portal (reservation); OPC UA server limits.	Concurrent privileged sessions limited/monitored.	
SR/CR 2.8	Auditable events	Enable the CPU **security event log** (auth, config change, firmware) and forward via **Syslog** to the SIEM; actions bind to the authenticated user/partner for attribution. **Ext. tools:** TIA Portal (security events); Syslog/SIEM review.	Security events logged, forwarded, and attributable.	
SR/CR 2.9	Audit storage capacity	The CPU log buffer is finite; forward security events to the SIEM for retention; confirm sizing and threshold alerting. **Ext. tools:** Syslog/SIEM retention review.	Events offloaded and retained; alert before capacity.	
SR/CR 2.10	Response to audit processing failures	Confirm the SIEM alerts if CPU event forwarding fails; local buffering continues so events are not silently lost. **Ext. tools:** SIEM agent-health / syslog-gap alert.	Audit-failure alerting defined.	
SR/CR 2.11	Timestamps	Confirm the CPU time is synced to the plant time source (NTP) so log/event timestamps are accurate and correlate across devices. **Ext. tools:** TIA Portal (time-of-day sync); NTP server check.	Reliable, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
EDR 2.13	Physical diagnostic & test interfaces	Control physical interfaces: the CPU **mode selector** (RUN/STOP) and memory-card slot in a locked panel, display access PIN, deactivate unused ports/Web/PROFINET diagnostics. **Ext. tools:** Physical inspection; TIA Portal (deactivated services).	Physical/diagnostic interfaces controlled; display PIN set.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	Enable **Secure Communication** (TLS): Secure PG/PC & HMI communication and Secure OUC; for the OPC UA server (FW V2.0+) set **SecurityPolicy Basic256Sha256** and **SecurityMode Sign & Encrypt** with X.509 certs from the **local/global certificate manager**; disable legacy PUT/GET (connection mechanisms) and unauthenticated S7comm; segment TCP 102. **Ext. tools:** Wireshark (encrypted/authenticated channels); OPC UA client (policy/mode check).	Comms integrity/confidentiality -protected (Sign&Encrypt); legacy PUT/GET off.	
SR/EDR 3.2	Protection from malicious code (component)	Confirm only Siemens-signed firmware and the compiled program run; know-how/copy protection prevents tampered logic; no arbitrary code execution path. **Ext. tools:** TIA Portal (firmware/know-how); signature review.	Only signed firmware/authorized logic runs; component protected.	EDR-specific.
SR/CR 3.3	Security functionality verification	After any change, re-verify the Protection & Security settings, know-how/copy protection, deactivated services, and certificates against the hardening baseline; compare the TIA project. **Ext. tools:** TIA Portal (compare to baseline); Nmap (confirm services off).	Security settings match the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Confirm program/logic integrity: **know-how protection** + **copy protection** (bind to memory-card/CPU serial), and change detection so unauthorized logic changes are prevented/detected. **Ext. tools:** TIA Portal (know-how/copy protection); online-vs-offline compare.	Program integrity protected; unauthorized change prevented/detected.	
SR/CR 3.5	Input validation	Confirm the CPU tolerates malformed PROFINET/S7/OPC UA frames without faulting. **ISOLATED only:** fuzz protocol interfaces on a representative CPU and watch cycle/connection health. **Ext. tools:** Protocol fuzzer / traffic generator (ISOLATED); Wireshark.	No crash or loss of control on malformed input.	Do NOT fuzz production.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.6	Deterministic output	Verify configured fail-safe behavior: output-module reaction to CPU STOP / comm loss (substitute/hold values), and for F-CPU the fail-safe values, so outputs assume a defined safe state. **Ext. tools:** TIA Portal (output reaction / F-parameters review).	Outputs go to a defined/fail-safe state on fault or comm loss.	
SR/CR 3.7	Error handling	Confirm graceful fault handling via OB error organization blocks (OB80/82/86/121/122 etc.) and diagnostics buffer; errors handled without loss of control or info leakage. **Ext. tools:** TIA Portal (diagnostics buffer / error OBs).	Graceful fault handling; no crash, unsafe state, or info leak.	
SR/CR 3.8	Session integrity	Where Secure Comm / OPC UA / TLS is applied, sessions are integrity-protected against replay/hijack; confirm secured channels in use and legacy sessions disabled. **Ext. tools:** Wireshark (session inspection).	Sessions integrity-protected; replay/hijack prevented.	
SR/CR 3.9	Protection of audit information	Protect the security event transport (Syslog over TLS where supported) and the SIEM store; restrict who can read/clear CPU diagnostics. **Ext. tools:** SIEM access review; syslog transport check.	Audit records protected from unauthorized read/modify/delete.	
EDR 3.10	Support for updates	Update firmware only with **Siemens-signed** firmware via TIA Portal / Web server; the CPU validates the signature; plan controlled updates with rollback to a prior signed revision. **Ext. tools:** TIA Portal (firmware update / signature); Siemens ProductCERT advisory check.	Signed firmware updates only, with a controlled update + rollback path.	EDR-specific.
EDR 3.11	Physical tamper resistance/detection	Keep the CPU in a locked, sealed panel; mode selector and memory card controlled; the security event log records config/mode/firmware changes as tamper evidence. **Ext. tools:** Physical inspection; security event log review.	Enclosure locked/sealed; interfaces controlled; changes logged.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	The CPU accepts only Siemens-signed firmware (product-supplier root of trust); confirm the signing chain is intact and unsigned/altered firmware is rejected at load. **Ext. tools:** TIA Portal (firmware signature verify); attempt unsigned image (isolated) -> rejected.	Supplier signing root intact; unsigned/altered firmware rejected.	EDR-specific.
EDR 3.13	Provisioning asset-owner roots of trust	For Secure Comm / OPC UA, confirm the asset owner can provision/manage its own certificates and trust list (project/enterprise CA) rather than relying on defaults. **Ext. tools:** TIA Portal (certificate manager / trust list).	Asset-owner certificate provisioning supported and verified.	EDR-specific.
EDR 3.14	Integrity of the boot process	Confirm the CPU validates signed-firmware integrity before execution (secure boot chain); no unsigned/tampered firmware runs. Capture firmware version + status. **Ext. tools:** TIA Portal (firmware version/signature status).	Firmware integrity validated before execution; only signed firmware boots.	EDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, reset the CPU to factory settings and erase/destroy the SIMATIC memory card so program, know-how-protected blocks, and config are not recoverable. **Ext. tools:** TIA Portal (reset to factory); memory-card sanitize/destroy.	Sensitive program/config purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	Confirm modern crypto for Secure Comm / OPC UA / HTTPS (TLS 1.2/1.3, strong suites); disable legacy unauthenticated protocols; certificates managed. **Ext. tools:** testssl.sh; OPC UA security policy review.	Modern crypto in use; legacy/weak protocols disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation	Confirm the CPU sits in a controlled cell/zone behind a firewall / **SCALANCE S** (or industrial firewall); only required protocols (PROFINET/S7/OPC UA) cross the boundary; no flat network. **Ext. tools:** Nmap by zone; firewall/SCALANCE rule review.	CPU in a segmented zone; only required flows cross the boundary.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General Purpose Person-to-Person Communication Restrictions	**N/A.** Embedded device has no general-purpose person-to-person communications (email/IM/web).	N/A - justification recorded (not assessed as a control).	N/A
SR 5.4	Application Partitioning	**N/A.** Single-purpose device; no separable applications to partition (handled at the host/SCADA layer).	N/A - justification recorded (not assessed as a control).	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility	Confirm security events and diagnostics are readable/exportable and forwarded (Syslog) to the SIEM for continuous monitoring; the cell is passively monitored (IDS). **Ext. tools:** Syslog listener; passive OT IDS (e.g. mirror port).	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: the CPU connection-resource limits and cell firewall rate-limiting prevent a flood from denying control; monitor cycle time and connection load. **Ext. tools:** TIA Portal (connection/cycle load); traffic generator (ISOLATED).	Resources bounded; control continues under load.	
SR/CR 7.2	Resource management	Confirm the CPU limits resource exhaustion (max connections, communication load share, cycle-time monitoring) so a single service cannot starve control. **Ext. tools:** TIA Portal (comm load / cycle monitoring).	Resources bounded; no exhaustion-based loss of control.	
SR/CR 7.3	Control system backup	Confirm the TIA Portal project + CPU configuration are backed up (versioned, offline copy) and restore/recovery is tested so the CPU can be rebuilt to a known-good state. **Ext. tools:** Backup repository review; restore test (lab).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Confirm hardening: deactivate the Web server (or HTTPS-only), disable unused protocols/ports, SNMP hardened/off, and only required services enabled per the baseline. **Ext. tools:** TIA Portal (service config); Nmap (exposed services).	Least functionality; unused services disabled per baseline.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Confirm the CPU is inventoried (type, firmware, TIA version, module list) so vulnerabilities can be tracked against Siemens ProductCERT advisories. **Ext. tools:** ReadOnlyEnum; TIA Portal device/firmware inventory.	Accurate component/firmware inventory maintained.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
TIA Portal	Native config & protection review (all FRs)	Read the Protection & Security settings, know-how/copy protection, certificates, services, diagnostics, and firmware; compare to the hardening baseline.	Use a read/authorized project copy.
Nmap / ReadOnlyEnum	Exposed-service & zone enumeration (1.13, 5.x, 7.6, 7.8)	Enumerate 102/4840/80/443/SNMP from each zone; confirm only required services reachable.	Read-only; authorized.
Wireshark	Comms integrity / session review (3.1, 3.8, 1.2)	Confirm Secure Comm/OPC UA channels are encrypted+authenticated; legacy S7comm not in cleartext.	Passive capture.
testssl.sh / OPC UA client	TLS & OPC UA policy strength (1.8, 1.9, 4.3)	Check TLS versions/ciphers on 443/4840 and the OPC UA security policy (Basic256Sha256+).	Non-intrusive.
Protocol fuzzer / traffic generator	Input validation & DoS resilience (3.5, 7.1)	Malformed-frame / high-rate PROFINET/S7/OPC UA testing while watching cycle/connection health.	ISOLATED/non-production; written authorization.
Syslog listener + SIEM	Event forwarding & monitoring (2.8-2.10, 6.x)	Confirm CPU security events reach the SIEM; trigger a test auth/config event.	Coordinate with SIEM team.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.